

**Министерство образования Республики Беларусь
Учреждение образования
«Белорусский государственный университет
информатики и радиоэлектроники»**

**Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий**

**ОТЧЁТ
по лабораторной работе № 2 (часть 1)
по дисциплине
«Проектирование защищенных интеллектуальных
информационных систем»**

Тема: Оценка защищённости разработанного приложения VulnNotes

Выполнил:
студент группы 321701
Струнец Д. П.

Проверил:
Сальников Д. А.

Минск 2026

1 ПОСТАНОВКА ЗАДАЧИ

Целью лабораторной работы является разработка учебно-демонстрационного веб-приложения с функциями управления пользователями и данными, а также выполнение анализа его защищённости с точки зрения политики безопасности операционной системы, компонентов приложения и их взаимодействия, сетевой политики и конфиденциальности данных.

В соответствии с заданием приложение должно обеспечивать:

- добавление пользователя в систему (регистрация);
- авторизацию пользователя по идентификационным данным;
- создание, редактирование, удаление и поиск конфиденциальных данных;
- создание, редактирование, удаление и поиск неконфиденциальных данных;
- деавторизацию авторизованного пользователя (logout).

Дополнительно приложение подготовлено как стенд для последующей части работы (лабораторная работа № 2, часть 2) и намеренно содержит типовые уязвимости по классификации OWASP Top 10:2025, что позволяет наглядно продемонстрировать последствия ошибок проектирования и реализации.

2 КРАТКОЕ ОПИСАНИЕ РАЗРАБОТАННОГО ПРИЛОЖЕНИЯ

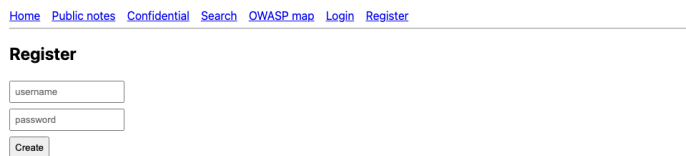
Разработано веб-приложение VulnNotes на языке Python (фреймворк Flask) с хранением данных в SQLite. Приложение упаковано в контейнер Docker на базе Ubuntu 22.04 и доступно по адресу <http://localhost:5050>. Процесс приложения выполняется от непривилегированного пользователя appuser.

Основные функции и маршруты:

- регистрация – /register; вход – /login; выход – /logout;
- публичные заметки (CRUD) – /public;
- конфиденциальные заметки (CRUD) – /confidential;
- поиск по заметкам – /search;

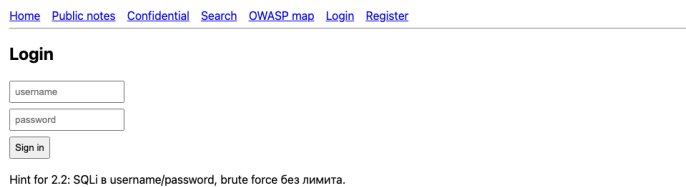
– карта уязвимостей – /vulns.

Для демонстрации предусмотрены учётные записи: admin/admin, alice/alice, bob/bob123, guest/guest. Ниже приведены снимки экрана основных сценариев.



The screenshot shows the 'Register' page of a web application. At the top, there is a navigation bar with links: Home, Public notes, Confidential, Search, OWASP.map, Login, and Register. Below the navigation bar, the title 'Register' is displayed. Underneath, there are two input fields: 'username' and 'password'. Below these fields is a 'Create' button.

Рисунок 1 – Страница регистрации пользователя



The screenshot shows the 'Login' page of a web application. At the top, there is a navigation bar with links: Home, Public notes, Confidential, Search, OWASP.map, Login, and Register. Below the navigation bar, the title 'Login' is displayed. Underneath, there are two input fields: 'username' and 'password'. Below these fields is a 'Sign in' button. At the bottom of the page, there is a hint: 'Hint for 2.2: SQLi в username/password, brute force без лимита.'

Рисунок 2 – Страница авторизации

Вход выполнен

VulnNotes

Учебное приложение с OWASP Top 10 уязвимостями. Не для production.

- Регистрация / логин / logout
- CRUD публичных заметок
- CRUD конфиденциальных заметок
- Поиск

Сид: admin/admin, alice/alice, bob/bob123, guest/guest

Рисунок 3 – Главная страница после входа (пользователь alice)

Public notes

#1 Welcome by admin
Публичная заметка для всех
[edit](#) | [delete](#)

#2 test by alice
test
[edit](#) | [delete](#)

#3 admin by admin
admin
[edit](#) | [delete](#)

Рисунок 4 – Список публичных (неконфиденциальных) заметок

[Home](#) [Public notes](#) [Confidential](#) [Search](#) [QWASP map](#) [Hi, alice \(user\)](#) [Logout](#)

Confidential notes

title

body

Create

#2 Alice private

Пароль от почты: Summer2020!

[open](#) | [edit](#) | [delete](#)

#3 test1

test1

[open](#) | [edit](#) | [delete](#)

IDOR: попробуй /confidential/1 будучи alice

Рисунок 5 – Список конфиденциальных заметок пользователя

[Home](#) [Public notes](#) [Confidential](#) [Search](#) [OWASP_map](#) Hi, alice (user) [Logout](#)

Search

Search

[XSS demo: вывести cookies на экран](#)

Query:

Browser cookies (HttpOnly=False → JS читает session):

```
session=eyJyYkx1TjoidXN1ci1aInVzZXI7aWQ1OjI39.aggBkQ.-Dt9wC1wEg8YFFYtyodGt8TX5tM
```

Search

Search

XSS demo: вывести cookies на экран

Query:

Browser cookies (HttpOnly=False → JS читает session):

```
session=eyJyb2xlIjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wCiwEqEHYFYtyodGtBTX5tM
```

Рисунок 6 – Страница поиска; демонстрация чтения cookie сессии

3 АНАЛИЗ ЗАЩИЩЁННОСТИ ПРИЛОЖЕНИЯ

3.1 Политика безопасности операционной системы

Приложение развёрнуто в контейнере Ubuntu 22.04. Положительные

стороны: процесс Flask не запускается от root, а от пользователя appuser; изолирована файловая система контейнера. Вместе с тем в образе намеренно оставлены учебные векторы повышения привилегий (SUID-утилита backup-tool, sudo NOPASSWD для find), что снижает защищённость ОС-контура и моделирует типичные ошибки администрирования.

3.2 Политика безопасности компонентов и их взаимодействия

Компоненты: веб-сервер Flask, СУБД SQLite (файл /app/data/app.db), сессионные cookie браузера. Взаимодействие реализовано через HTTP без TLS. Выявлены нарушения: SQL-инъекции в /login и /search; отражённый XSS на /search; IDOR при доступе к /confidential/<id>; открытый API /api/notes/<id> без авторизации; небезопасная десериализация pickle на /import; SSRF на /fetch; DEBUG=True и эндпоинт /debug/config с утечкой secret_key; пароли в БД в открытом виде; SESSION_COOKIE_HTTPONLY=False.

[Home](#) [Public notes](#) [Confidential](#) [Search](#) [OWASP map](#) Hi, alice (user) [Logout](#)

OWASP Top 10:2025 — карта уязвимостей

owasp.org/Top10/2025

ID	Категория	Где в приложении
A01	Broken Access Control	IDOR /confidential/<id>, /api/notes; SSRF /fetch
A02	Security Misconfiguration	DEBUG=True, /debug/config, hardcode secret
A03	Software Supply Chain Failures	старые deps без hashes (requirements.txt)
A04	Cryptographic Failures	plaintext passwords, нет TLS
A05	Injection	SQLi /login и /search; XSS /search?q=
A06	Insecure Design	нет rate limit / MFA / политики паролей
A07	Authentication Failures	слабые пароли, cookie без HttpOnly
A08	Software or Data Integrity Failures	/import pickle.loads
A09	Security Logging and Alerting Failures	failed login не пишется
A10	Mishandling of Exceptional Conditions	SQL/exception text в ответе /search

[SSRF \(A01\)](#) · [Pickle \(A08\)](#) · [Debug \(A02\)](#) · [Bad SQL \(A10\)](#)

Рисунок 7 – Карта уязвимостей OWASP Top 10:2025 в приложении

Вход выполнен

VulnNotes

Учебное приложение с OWASP Top 10 уязвимостями. Не для production.

- Регистрация / логин / logout
- CRUD публичных заметок
- CRUD конфиденциальных заметок
- Поиск

Сид: admin/admin, alice/alice, bob/bob123, guest/guest

Рисунок 8 – Обход авторизации SQL-инъекцией в поле username

Confidential #1

owner_id=1

Admin secret

SSN: 123-45-6789; card: 4111111111111111

Рисунок 9 – IDOR: alice читает чужую конфиденциальную заметку /confidential/1

SQL error: near "style": syntax error

```
SELECT id, title, body, 'public' AS kind FROM public_notes WHERE title LIKE '%
```

```
Stolen cookies:
session=eyJyb2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wCiwEgEHYFYtyodGtBTX5tM
```

```
% ' OR body LIKE '%
```

```
Stolen cookies:
session=eyJyb2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wCiwEgEHYFYtyodGtBTX5tM
```

```
% ' UNION ALL SELECT id, title, body, 'confidential' AS kind FROM confidential_notes WHERE title LIKE '%
```

```
Stolen cookies:
session=eyJyb2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wCiwEgEHYFYtyodGtBTX5tM
```

```
% ' OR body LIKE '%
```

```
Stolen cookies:
session=eyJyb2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wCiwEgEHYFYtyodGtBTX5tM
```

```
% '
```

Рисунок 10 – XSS: вывод document.cookie (кража сессии)

```
Pretty-print ☐
{
  "db_path": "/app/data/app-db",
  "debug": true,
  "secret_key": "super-secret-hardcoded-key-12345",
  "users_hint": "admin/admin, alice/alice"
}
```

Рисунок 11 – Утечка конфигурации через /debug/config

[Home](#) [Public notes](#) [Confidential](#) [Search](#) [OWASP map](#) Hi, alice (user) [Logout](#)

Search

'

[XSS demo: вывести cookies на экран](#)

Query: '

Browser cookies (HttpOnly=False → JS читает session):

```
session=eyJyb2x1IjoIdXN1c1R1a1VzIXF1aWQ1d3J9.apgBkQ_-Dt9wClWgE5TF7tyodC1STX5tM
```

Home Public notes Confidential Search QWASP map Hi, alice (user) Logout

URL Fetch (SSRF demo)

3.3 Сетевая политика безопасности

3.4 Сводка по OWASP Top 10:2025

В приложении воспроизведены категории A01–A10 (2025): Broken Access Control (в т.ч. SSRF), Security Misconfiguration, Software Supply Chain Failures, Cryptographic Failures, Injection, Insecure Design, Authentication Failures, Software/Data Integrity Failures, Security Logging Failures, Mishandling of Exceptional Conditions. Подробная карта доступна на странице /vulns и в сопроводительной документации лабораторной работы.

4 АНАЛИЗ ЗАЩИЩЁННОСТИ КОНФИДЕНЦИАЛЬНОЙ ИНФОРМАЦИИ

Конфиденциальные заметки хранятся в таблице `confidential_notes` без шифрования «на диске». Разграничение доступа на уровне списка (`WHERE owner_id = ?`) легко обходится IDOR и неавторизованным API. Пароли пользователей хранятся в открытом виде, поэтому компрометация файла БД приводит к полной утрате учётных данных. Cookie сессии доступна JavaScript (отсутствие `HttpOnly`), что в сочетании с XSS позволяет похитить сессию и выдать себя за пользователя.

Таким образом, конфиденциальность данных в текущей реализации не обеспечена: нарушены принципы `least privilege`, `secure defaults`, `defense in depth` и безопасной обработки ошибок.

Рекомендации по повышению защищённости (для исправленной версии):

- параметризованные SQL-запросы и экранирование вывода (защита от SQLi/XSS);
- проверка владельца ресурса на каждом CRUD-операции; аутентификация API;
- хэширование паролей (`bcrypt/argon2`), TLS, флаги cookie `HttpOnly/Secure/SameSite`;
- отключение `DEBUG`, удаление `/debug/config`, единый обработчик ошибок без утечек;
- запрет `pickle` от пользователя; `allowlist` для SSRF; `rate limit` и аудит логов;
- шифрование at-rest для `confidential_notes` и жёсткая политика ОС (без лишнего SUID).

5 ВЫВОД

Семантическая составляющая. В ходе работы реализовано веб-приложение VulnNotes, поддерживающее регистрацию, авторизацию, logout, CRUD и поиск публичных и конфиденциальных данных. Выполнен анализ защищённости с точки зрения ОС, компонентов, сети и конфиденциальности; идентифицированы критические дефекты, соответствующие актуальным категориям OWASP Top 10:2025.

Прагматическая составляющая. Полученный стенд пригоден для демонстрации атак и последующей отработки методов эксплуатации и повышения привилегий (лабораторная работа № 2, часть 2). Результаты анализа показывают, что без целенаправленных мер защиты даже функционально полное приложение не обеспечивает сохранность конфиденциальной информации.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Ховард, М. Защищённый код / М. Ховард, Д. Лебланк. – М. : Русская редакция, 2004. – 704 с.
2. Ховард, М. 24 смертных греха компьютерной безопасности / М. Ховард, Д. Лебланк, Дж. Вьегга. – СПб. : Питер, 2010. – 400 с.
3. OWASP Top 10:2025 [Электронный ресурс]. – Режим доступа: <https://owasp.org/Top10/2025/>.
4. Flask Documentation [Электронный ресурс]. – Режим доступа: <https://flask.palletsprojects.com/>.